

# UAA8

# Sécurité des données

## Correctif



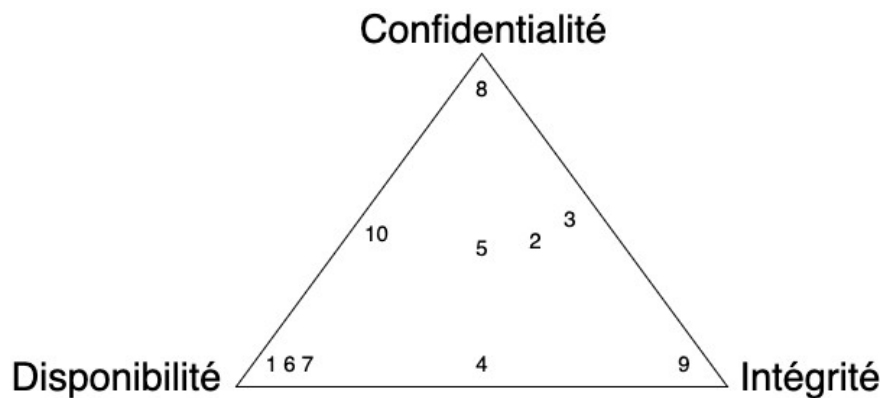
Technique de transition  
–  
Option Informatique  
–  
Titulaire du cours : L. Embrechts

# Table des matières

|                                                                |          |
|----------------------------------------------------------------|----------|
| <b>1. Correctif.....</b>                                       | <b>3</b> |
| 1.1. Triade CID.....                                           | 3        |
| 1.2. Les droits d'accès.....                                   | 4        |
| 1.2.1. Droit d'accès le plus pertinent.....                    | 4        |
| 1.2.2. Avantages et inconvénients de la gestion par rôles..... | 5        |
| 1.3. Système d'authentification.....                           | 5        |
| 1.4. Chiffrement des données.....                              | 6        |
| 1.4.1. Comparatif messageries.....                             | 6        |
| 1.5. Chiffrement des données.....                              | 7        |

# 1. Correctif

## 1.1. Triade CID



| Service                                                | Position sur la triade                 | Justification                                                                                                     |
|--------------------------------------------------------|----------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Spotify                                                | Proche de Disponibilité                | Accès continu privilégié ; confidentialité et intégrité sont secondaires.                                         |
| WhatsApp                                               | Entre Confidentialité et Intégrité     | Messages privés et non modifiables.                                                                               |
| Dossier médical en ligne                               | Entre Confidentialité et Intégrité     | Données de santé sensibles nécessitant confidentialité et exactitude.                                             |
| Classroom                                              | Entre Intégrité et Disponibilité       | Fiabilité des devoirs et accès permanent nécessaires.                                                             |
| Application bancaire en ligne                          | Centre du triangle                     | Tous les piliers sont critiques : secret bancaire, exactitude et disponibilité du service.                        |
| Système d'alarme incendie connecté                     | Proche de Disponibilité                | Alerte indispensable, disponibilité prioritaire.                                                                  |
| TikTok                                                 | Entre Disponibilité et Intégrité       | Plateforme accessible en continu où la fiabilité des contenus est importante.                                     |
| GlobaLeaks / plateforme d'anonymat lanceurs d'alerte   | Proche de Confidentialité seule        | Confidentialité totale primordiale ; disponibilité et intégrité secondaires, pas de stockage critique persistant. |
| <b>Système de vote électronique (e-Voting Estonie)</b> | <b>Proche d'Intégrité unique</b>       | Garantit que les votes ne sont ni modifiés ni falsifiés, assurant la fiabilité absolue du scrutin.                |
| Plateforme e-commerce                                  | Entre Confidentialité et Disponibilité | Protection des données clients et accessibilité prioritaires, intégrité importante mais secondaire.               |

## 1.2. Les droits d'accès

### 1.2.1. Droit d'accès le plus pertinent

| Situation                                                                                           | (r / w / x) | Justification (corrigé)                                                    |
|-----------------------------------------------------------------------------------------------------|-------------|----------------------------------------------------------------------------|
| Ouvrir et lire un PDF<br>"Consignes_devoir.pdf" dans un dossier partagé.                            | r           | Lire/consulter sans modifier.                                              |
| Modifier ton fichier "rapport.docx" puis l'enregistrer.                                             | w           | Écriture = modifier et enregistrer.                                        |
| Dossier "Devoirs_à_rendre" sert uniquement à déposer ton fichier final (sans voir ceux des autres). | w           | Déposer = créer/ajouter un fichier (écriture).                             |
| Lancer un programme "Calculatrice" installé sur l'ordinateur.                                       | x           | Exécution = lancer un programme.                                           |
| Le fichier "script_sauvegarde.sh" doit pouvoir être lancé par l'administrateur.                     | x           | Un script doit être exécutable pour être lancé.                            |
| Dossier "Photos_de_classe" consultable par tous, mais personne ne doit ajouter/supprimer.           | r           | Consultation uniquement, pas de modification.                              |
| Fichier "notes.csv" doit être corrigé par l'enseignant, pas par les élèves.                         | w           | Corriger = modifier (écriture) pour le rôle autorisé.                      |
| Dossier "Logiciels" : les élèves lancent des applis installées, mais n'ajoutent pas de programmes.  | x           | Ici, l'action principale est "lancer"; on évite w pour empêcher l'ajout.   |
| Lire un fichier de configuration sans le modifier.                                                  | r           | Lecture seule.                                                             |
| Dossier "Partage_Classe" pour déposer des fichiers de projet commun.                                | w           | Déposer/ajouter = écriture.                                                |
| Consulter "presentation.pptx" pendant un exposé, sans modification.                                 | r           | Lecture seule.                                                             |
| Dossier "Rendus_Exam" : déposer, sans supprimer ni modifier après dépôt.                            | w           | Déposer = écrire; (idéalement écriture limitée, mais parmi r/w/x c'est w). |

### 1.2.2. Avantages et inconvénients de la gestion par rôles

|                    | Avantages de gérer par rôles                                                                                                | Inconvénients de gérer par rôles                                                        |
|--------------------|-----------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| <b>Simplicité</b>  | Administration plus simple : il suffit d'attribuer les droits à un rôle, puis de l'associer à un utilisateur.               | Moins de flexibilité pour des besoins très spécifiques à un individu.                   |
| <b>Cohérence</b>   | Standardisation : tous les membres d'un même rôle disposent des mêmes permissions, limitant les erreurs et incohérences.    | Risque de "droits excessifs" si le rôle est trop large pour certains utilisateurs.      |
| <b>Scalabilité</b> | Ajout, modification ou suppression de droits rapide : changer le rôle suffit pour affecter tous les utilisateurs concernés. | Difficile de répondre à l'évolution des besoins particuliers sans multiplier les rôles. |
| <b>Sécurité</b>    | Meilleure traçabilité et audit des droits : le contrôle est centralisé et moins d'oublis lors des changements.              | Si un seul rôle est compromis, tous les membres peuvent être impactés.                  |

### 1.3. Système d'authentification

Facteur de connaissance :

| <i>Avantages</i>                                 | <i>Inconvénients</i>                                                    |
|--------------------------------------------------|-------------------------------------------------------------------------|
| Familier<br>Facile à implémenter<br>Coût minimal | Vulnérable au phishing<br>Souvent réutilisé<br>Peut être deviné ou volé |

Facteur de possession :

| <i>Avantages</i>                                           | <i>Inconvénients</i>                                            |
|------------------------------------------------------------|-----------------------------------------------------------------|
| Difficile à dupliquer<br>Peut être indépendant des réseaux | Peut être perdu ou volé<br>Nécessite un appareil supplémentaire |

Facteur inhérent :

| <i>Avantages</i>                                                                    | <i>Inconvénients</i>                                                                             |
|-------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| Impossible à oublier<br>Très difficile à falsifier<br>Expérience utilisateur fluide | Problèmes de confidentialité<br>Coût d'implémentation élevé<br>Risques de faux positifs/négatifs |

Facteur contextuel :

| <i>Avantages</i>                                                    | <i>Inconvénients</i>                                                                     |
|---------------------------------------------------------------------|------------------------------------------------------------------------------------------|
| authentification transparente<br>surveillance continue<br>adaptatif | algorithmes complexes<br>apprentissage initial nécessaire<br>variations comportementales |

Authentification MFA :

| <i>Type</i> | <i>Action</i>                                    | <i>Méthodes</i>                                                                                                                                    |
|-------------|--------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| 1FA         | Déver. d'un smartphone                           | Code PIN (facteur de connaissance)<br>ou<br>Empreinte (facteur inhérent)                                                                           |
| 2FA         | Connexion à un réseau social ou à une messagerie | Mot de passe (connaissance) + Code SMS (possession)                                                                                                |
| 3FA         | Accès à une application bancaire sensible        | Code PIN (connaissance) + itsme <sup>®</sup> (possession)+ scan visage (inhérent)                                                                  |
| 4FA         | Accès administratif ultra-sécurisé               | Mot de passe (connaissance) + Clé USB ou carte à puce (possession) + Empreinte (inhérent) + Vérification de localisation (contexte/comportemental) |

Les 5 critères qui permettent d'évaluer la robustesse d'un mot de passe :

1. longueur (selon la CNIL, il faut au moins 12 symboles)
2. prévisibilité
3. présence de mot du dictionnaire
4. présence de caractères spéciaux
5. la variété (selon la CNIL, il faut alterner entre majuscules, minuscules, nombres et caractères spéciaux )

## 1.4. Chiffrement des données

### 1.4.1. Comparatif messageries

| Messagerie | Chiffrement de bout en bout ? | Code source ouvert ? | Messages autodestructibles ? | Stockage local ? | Aucune donnée collectée ? |
|------------|-------------------------------|----------------------|------------------------------|------------------|---------------------------|
| Telegram   | Oui                           | Non                  | Oui                          | Non              | Oui                       |
| Signal     | Oui                           | Oui                  | Oui                          | Oui              | Oui                       |
| WhatsApp   | Oui                           | Non                  | ?                            | Oui              | Non                       |
| iMessage   | Oui                           | Non                  | Oui                          | Non              | Oui                       |

Quel est le meilleur service de messagerie en matière de confidentialité ?

Signal.

### 1.5. Chiffrement des données

| Hash                             | Mot de passe déchiffré     |
|----------------------------------|----------------------------|
| 5f4dcc3b5aa765d61d8327deb882cf99 | password                   |
| e99a18c428cb38d5f260853678922e03 | abc123                     |
| 7b0a7e4d05c63ae18e58c6c21f699485 | qz2\$71Uc9p                |
| 0d107d09f5bbe40cade3de5c71e9e9b7 | letmein                    |
| 67d23692bf970da6d0d2d7bd5840001f | azertyuiopqsdfghjklmwxcvbn |

Remarque : ce n'est donc pas parce qu'un mot de passe est long qu'il est forcément sécurisé. Car l'attaque par dictionnaire se base sur la fréquence d'utilisation du mot de passe.